



CIBERSEGURIDAD EN ENTORNOS DE LAS TECNOLOGÍAS DE LA INFORMACIÓN

Normativa de Ciberseguridad

TEMA 4

Legislación y jurisprudencia en materia de protección de datos
Alberto Diéguez Álvarez

Tabla de contenido

1.- Descripción de la tarea.....	3
Caso práctico	3
Apartado 1: Legitimación y Transferencias Internacionales	4
Apartado 2: Gestión de Consentimiento Web.....	5
Apartado 3: Cumplimiento Normativo Corporativo	6
Apartado 4: Inteligencia Artificial y Datos Biométricos	6

1.- Descripción de la tarea

Caso práctico



[isftic](#). Antena de Telecomunicaciones ([CC BY-NC-SA](#))

La compañía ACME S.A. sigue creciendo. Mantiene sus 300.000 clientes y su sede inteligente en Madrid. Sin embargo, para este año fiscal, la dirección ha lanzado el plan de modernización "ACME 2025" que incluye:

- La contratación de un CRM en la nube alojado en servidores de California (EE.UU.) para gestionar los datos de todos los clientes.
- El lanzamiento de una nueva campaña de marketing digital que requiere rastrear la navegación de los usuarios en su web.
- La implementación de un sistema de Inteligencia Artificial para analizar las emociones de los empleados mediante las cámaras de seguridad y mejorar el clima laboral.

Debido a su tamaño y volumen de negocio, se han detectado posibles irregularidades financieras internas que nadie se atreve a reportar.

¿Qué te pedimos que hagas?

Actuando como el nuevo delegado de Protección de Datos (DPO) de ACME S.A., debes emitir un informe jurídico-técnico respondiendo a los siguientes retos planteados por la dirección.

Apartado 1: Legitimación y Transferencias Internacionales

La dirección quiere migrar la base de datos de clientes al proveedor estadounidense "SiliconData Inc.". El director técnico dice: *"Hace dos años esto era un infierno legal, mejor no lo hagamos"*.

1. Explica a la dirección cuál es la situación actual (post-julio 2023) respecto a las transferencias de datos a EE.UU.

Como se nos muestra en la agenda de actualización normativa, desde julio de 2023 la Comisión Europea aprobó el EU-US Data Privacy Framework. Esto significa que la UE emitió una decisión de adecuación, que quiere decir que se vuelve a considerar que EE.UU. ofrece un nivel de protección equiparable al europeo.

Las empresas de EE.UU. pueden certificarse en este marco. Si la empresa proveedora está en la lista certificada, los datos pueden ir libremente desde Europa sin pasar por autorizaciones especiales.

El impacto que esto tiene es que facilita el uso de proveedores tecnológicos americanos para las empresas europeas.

Resumiendo:

- Existe decisión de adecuación.
- EE.UU. vuelve a considerarse con nivel de protección equiparable.
- Ya no es necesario aplicar mecanismos complejos si el proveedor está adherido.

2. ¿Qué verificación específica debes realizar sobre "SiliconData Inc." para que la transferencia sea legal sin necesitar autorizaciones complejas? (referencia al Data Privacy Framework).

Pues deberá comprobarse que esta está certificada en el Data Privacy Framework y que está en la lista oficial de las empresas adheridas a la misma. Si todo está certificado la consecuencia es que la transferencia es legal sin autorizaciones adicionales.

Apartado 2: Gestión de Consentimiento Web

El equipo de marketing ha diseñado un nuevo banner de cookies para la web. Actualmente se ve así:

Texto: "Usamos cookies para mejorar tu experiencia." Botón 1 (Verde, Grande): [ACEPTAR TODO] Enlace (Pequeño, Gris): "Configurar opciones" (al hacer clic lleva a un menú donde se puede desmarcar manualmente).

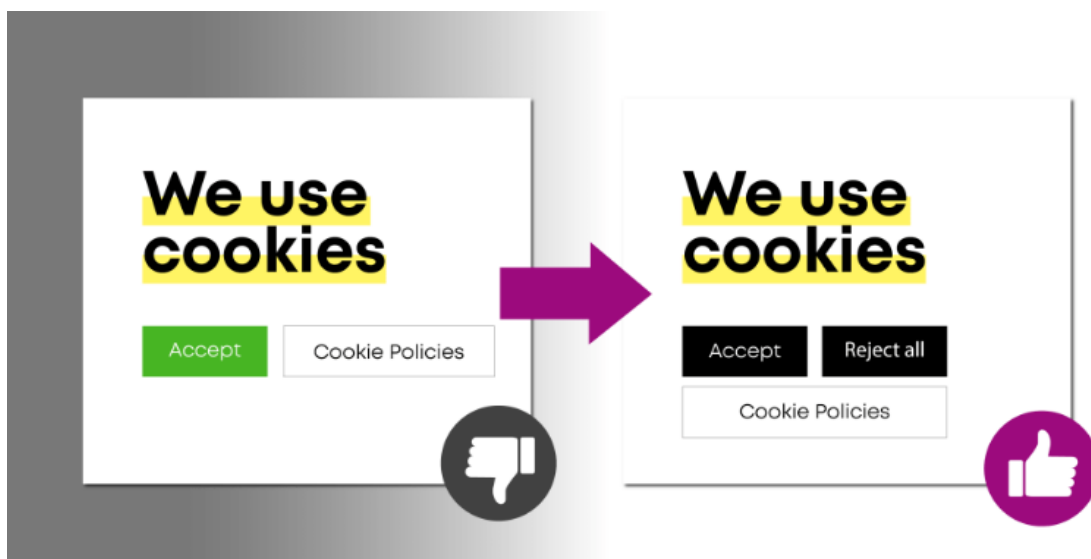
1. Analiza la legalidad de este banner según la normativa actual de la AEPD. ¿Es sancionable? ¿Por qué?

El banner no es legal, ya que desde julio de 2023 es obligatorio que el botón de rechazar esté al mismo nivel que el de aceptar, además tienen que tener la misma visibilidad y el mismo diseño para no sugerir. También evitar los patrones oscuros que no puede ser más difícil rechazar que aceptar.

Sabiendo esto, determinamos que el banner que se pretende implementar es sancionable, ya que oculta de manera sutil el botón de rechazar en una capa de configuración.

2. Dibuja o describe cómo debe ser obligatoriamente la primera capa de información de ese banner para cumplir con la ley (paridad de botones).

Buscando más información por internet me encontré esta imagen que lo refleja muy bien.



En ella podemos ver que tanto el botón de aceptar como el de rechazar están al mismo nivel y en las mismas condiciones.

Apartado 3: Cumplimiento Normativo Corporativo

ACME tiene más de 50 empleados y factura millones de euros. Se sospecha de un fraude interno, pero los empleados tienen miedo a represalias si hablan.

- 1. Según la Ley 2/2023, ¿está obligada ACME a implantar un sistema interno de información (Canal de Denuncias)? Justifica tu respuesta por volumen de empleados.**

Sí, ACME está obligada ya que según la ley 2/2023 dice que las empresas con 50 o más trabajadores han de implementar un Sistema de Información (Canal de Denuncias)

- 2. El CEO propone que las denuncias se envíen a su correo personal (ceo@acme.sa) y que el denunciante deba firmar con su nombre y DNI obligatoriamente. ¿Es esto legal? Explica el requisito de anonimato/confidencialidad.**

Esa propuesta no es legal, ya que la ley exige que el canal debe permitir denuncias anónimas, además que el acceso a los datos de la denuncia solo será revisable por los responsables del sistema (RRHH o Compliance).

Apartado 4: Inteligencia Artificial y Datos Biométricos

Sobre la propuesta de usar las cámaras de seguridad para "analizar emociones de empleados" mediante IA:

- 1. Identifica qué tipo de dato se estaría tratando (¿es un dato básico o de categoría especial según el art. 9 del RGPD?).**

El uso de cámaras con Inteligencia Artificial nos dice que están haciendo uso de datos genéticos y biométricos que son considerados datos especialmente sensibles.

2. Basándote en el Reglamento Europeo de IA, clasifica este sistema. ¿Es un sistema de alto riesgo, de riesgo limitado o una práctica prohibida?

Según el Reglamento Europeo de Inteligencia Artificial (2024) quedan prohibidos los sistemas de IA que sean de `riesgo inaceptable`, que como en este caso atañen a los datos biométricos que se quieren utilizar para la identificación remota, solo podría implementarse en excepciones policiales muy graves.

Notas:

- <https://www.boe.es/buscar/doc.php?id=DOUE-L-2024-81079>